IPB University — Bogor Indonesia | Sekolah Vokasi — School of Vocational Sciences

Simulated SOC Engagement

Mengamankan Infrastruktur Backend pada SASSY (Smart Automatic Steaming System)

Sistem *Monitoring* dan Kontrol Otomatis Proses Pengukusan *Ecoprint* Berbasis IoT



IPB University — Bogor Indonesia — | Sekolah Vokasi — School of Vocational Sciences



Tim Project Based Learning



Nailah Syarifah Sagala

Lead

NIM. J0404241082



Fachryreza Andaris A.

Blue Team

NIM. J0404241004



M. Faza Munsya'ari

Blue Team

NIM. J0404241169



Zahra Ridha Febyanti

Red Team

NIM. J0404241105

IPB University — Bogor Indonesia | Sekolah Vokasi — School of Vocational Sciences



Kontrol Suhu Otomatis

Menjaga stabilitas suhu ruang pengukusan di suhu target secara presisi



Monitoring IoT Otomatis

Pemantauan suhu dan durasi secara kontinu melalui dashboard web interaktif.



Proteksi Keselamatan

Sistem deteksi dini kebocoran gas LPG dan kegagalan api pembakaran.

SASSY

Sistem Automatic Steaming System

Sistem monitoring dan kontrol otomatis proses pengukusan kulit ecoprint berbasis IoT untuk mewujudkan prodeksi modern, presisi dan aman.

Fitur Alat

Authentication & Access Control

Memastikan hanya pengguna terdaftar yang dapat mengakses dashboard dan membatasi tindakan berdasarkan hak akses.

IoT Communication Security

Mengamankan komunikasi antara ESP32-S3 dan server, misalnya menggunakan MQTT dengan TLS serta autentikasi perangkat.

Database & API Security

Membatasi akses database, mengamankan endpoint API, memvalidasi input, & mencegah akses/perubahan data tanpa izin.

Security Monitoring & Audit Log

Mencatat aktivitas login, kegagalan autentikasi, permintaan API, dan perubahan konfigurasi untuk membantu investigasi insiden.

IPB University — Bogor Indonesia | Sekolah Vokasi — School of Vocational Sciences

Topologi Sistem



Node	Sistem Operasi/Peran	Alamat IP
Attacker Node	**Kali Linux**	**192.168.10.100**
Target Node	Ubuntu Server CLI	192.168.10.10
Monitoring Node	**Security Onion**	**192.168.10.50**

Deklarasi

Tech Stack & Replikasi

Tech Stack	Komponen Arsitektur Asli	Komponen Arsitektur Replika	Layanan Port
Sistem Operasi Backend	Cloud Platform / PaaS (Supabase Cloud & Render)	Ubuntu Server 22.04 LTS (CyberOps Lab VM)	
Database/ Penyimpanan	Supabase Cloud Database (PostgreSQL + Realtime)	MySQL Server 8.0 / PostgreeSQL Lokal	Port 3306/tcp
Dashboard/ Web App	Next.js Dashboard (Vercel) + FastAPI (Render)	Nginx Web Server + HTML/JS Dashboard	Port 80/tcp (HTTP
Komunikasi & API	Cloud Web Console & Git Deployment	Eclipse Mosquitto v2.0 & Python Flask API	Port 1883/tcp & 5000/tcp
Manajemen Remote	Cloud Web Console & Git Deployment	OpenSSH Server (Hardened, Key-Auth Only)	Port 2222/tcp (SSH)

IPB University — Bogor Indonesia | Sekolah Vokasi — School of Vocational Sciences

Progres
Hardening pada sistem IoT

Access & Authentication — 100%

- Nonaktifkan Root Login: PermitRootLogin no di /etc/ssh/sshd_config. Login root ditolak sistem.
- SSH Key-Based Auth: Wajib kunci RSA 2048-bit, password auth dimatikan total (PasswordAuthentication no).
- Ubah Port SSH: Port standar 22 dipindahkan ke port custom 2222. Port 22 connection refused.
- Anti Brute-Force Fail2ban: Proteksi jail sshd aktif di port 2222 (maxretry = 3, bantime = 600s).

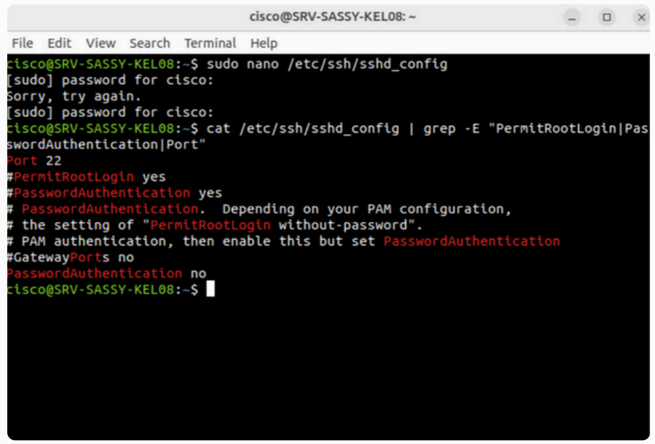
Service & Attack Surface — 100%

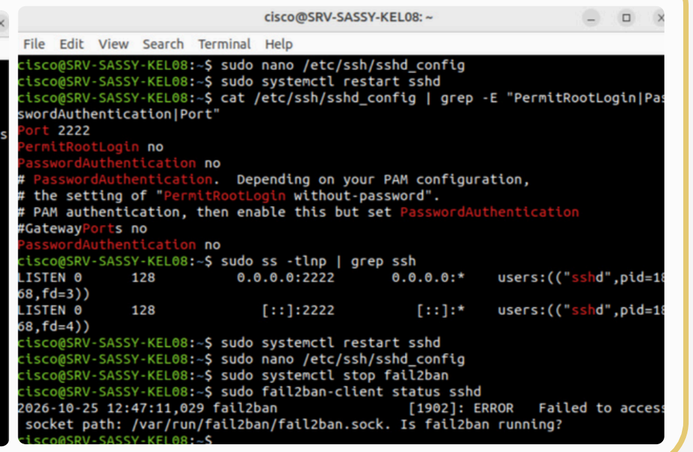
- Firewall UFW Ketat: Kebijakan default deny incoming, hanya whitelist port esensial (2222, 1883, 3306, 80, 5000).
- Matikan Service Non-Esensial: Menonaktifkan service discovery & printer (cups, avahi-daemon, rpcbind).
- OS & Paket Patching: Repositori dan security patch mutakhir (apt update & apt upgrade).
- Pengamanan Kredensial MySQL: Hapus anonymous user, cabut akses remote root database.

Data & Application — 100%

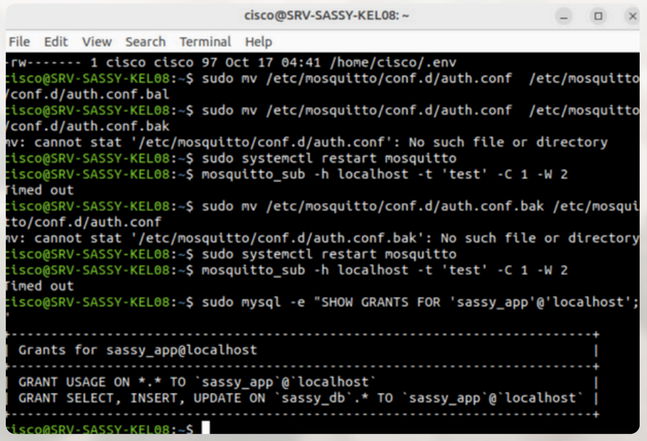
- Isolasi Kredensial: Kredensial DB/MQTT dipisah ke file .env dengan hak akses terbatas (chmod 600).
- Wajib Autentikasi MQTT: Mosquitto menolak akses anonim (allow_anonymous false), wajib user sassy_client.
- Least Privilege User DB: User aplikasi sassy_app dibatasi hanya CRUD pada database sassy_db.
- Audit Trail & Logging: Logging aktif pada auth.log, mosquitto.log, dan fail2ban.log.

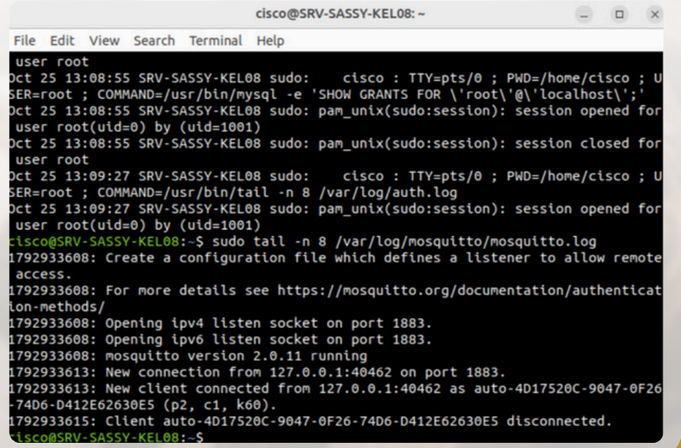
Sebelum Hardening





Sesudah Hardening





IPB University — Bogor Indonesia — Sekolah Vokasi School of Vocational Sciences

Attack Plan (Red Team)

Skenario 1 (Reconnaissance)

Port scanning menggunakan **Nmap** (nmap -sV -p-) ke Target Node 192.168.10.10 untuk memetakan seluruh port terbuka dan versi service yang berjalan.
Alasan: Nmap merupakan tool reconnaissance standar untuk memetakan attack surface, merepresentasikan tahap awal serangan nyata.

Skenario 2 (Exploitation/Access)

Brute-force SSH menggunakan **Hydra** dengan wordlist rockyou.txt ke port 2222 untuk menguji ketahanan autentikasi SSH, khususnya apakah password authentication masih aktif atau sudah dibatasi ***key-based auth.***
Alasan: Hydra + rockyou.txt merupakan wordlist berisi 14+ juta password dari kebocoran data nyata (RockYou 2009), menguji ketahanan terhadap pola password lemah yang umum dipakai pengguna sungguhan.

Skenario 3 (Web/API/Protokol IoT)

Unauthorized access ke Mosquitto MQTT Broker menggunakan mosquitto_sub/pub — menguji apakah broker menerima koneksi anonymous atau kredensial default/umum, relevan dengan protokol komunikasi sensor SASSY berbasis MQTT.
Alasan: mosquitto_sub/pub merupakan client resmi protokol MQTT yang sama dengan yang dipakai SASSY, menguji celah autentikasi broker yang umum terjadi pada implementasi IoT.



Terima kasih.

Saatnya kita memilih jalur ekonomi berkelanjutan yang memanusiakan sesama dan menjaga semesta!